CASO DE ESTUDIO · ALIMENTOS

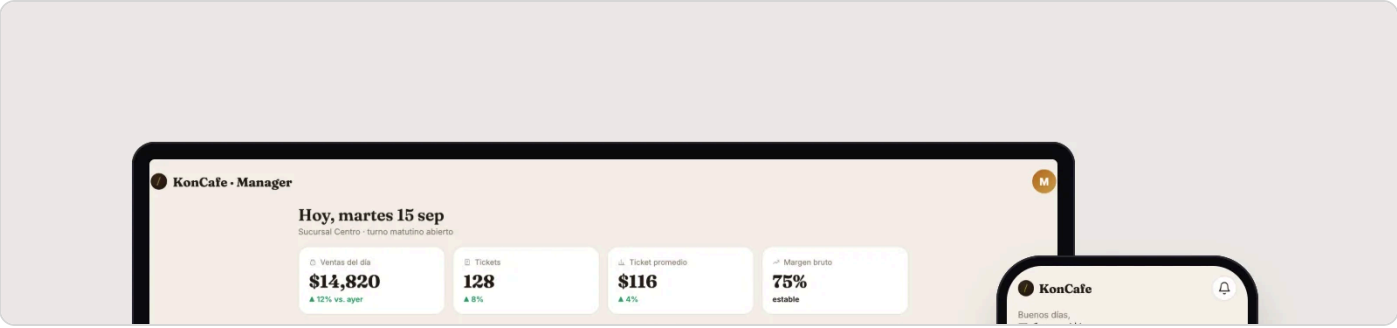
KonCafe

Cafetería con app de pedidos y kiosko · Sep 2026

Auditoría entregada + plan por versiones

Alan Daniel Méndez Jiménez
Software a medida · Celaya, Gto.
+52 466 160 3682
alannicanor62@gmail.com

Auditoría de seguridad de una app existente hecha por terceros, corrección de lo crítico y plan para evolucionarla por versiones.



EL PROBLEMA

- La app de clientes y punto de venta (hecha por otro proveedor) exponía la base de clientes completa a cualquiera en internet.
- Cualquiera podía inyectar pedidos sin cuenta y el PIN del personal estaba en claro.
- El dueño no sabía qué tan grave era ni por dónde empezar.

LA SOLUCIÓN

- Pentest de caja negra autorizado (13–14 sep 2026): pruebas activas no destructivas sobre Firestore, Auth, Storage, cabeceras y análisis del código publicado.
- Informe con severidades y evidencia, runbook de corrección paso a paso y reglas de base de datos listas para desplegar.
- Dashboard con las ventas y clientes reconstruidos desde los datos expuestos, para dimensionar el impacto con sus propios números.
- Plan por versiones: base segura → cobros blindados → app estable → nueva imagen → pedir-y-recoger con pago móvil. Cada versión se entrega funcionando.

EL RESULTADO

- Re-test en vivo: fuga de datos personales cerrada (403), inyección de pedidos cerrada y PIN fuera del cliente.
- De 3 hallazgos críticos a 0; quedan medios y bajos con plan de corrección.
- Prototipo navegable de cómo se vería la app bien construida (cliente, kiosko y panel del gerente).

Pentest | Firebase (Firestore, Auth, App Check) | React + Vite | Python | Prototipo HTML

Caso completo: alanmendez.dev/casos/koncafe

Quiero algo así · WhatsApp